

Relatório de Segurança

Análise de Possível Vazamento de Credenciais

Data: 01/04/2026 | Cliente afetado: Forcell | Solicitante: Turbo Partners | Analista: Equipe de Tecnologia

1. Resumo Executivo

Após investigação técnica detalhada no repositório de código, banco de dados e infraestrutura do Cortex (plataforma interna da Turbo Partners), não foi identificada nenhuma evidência de que as credenciais do cliente Forcell tenham sido expostas ou comprometidas por falha na infraestrutura da Turbo.

2. Investigação Realizada

2.1 Repositório de Código (GitHub)

- * **Status do repositório:** Privado - acesso restrito apenas a colaboradores autorizados da Turbo.
- * **Arquivo .env:** Nunca foi commitado no repositório. Apenas o .env.example (sem credenciais reais) existe no histórico do Git.
- * **Busca no histórico completo:** Foi realizada uma varredura em todos os 3.627 commits do repositório buscando por credenciais de clientes. Nenhuma credencial de cliente foi encontrada em nenhum commit.
- * **Credenciais de clientes (/acessos):** São armazenadas exclusivamente no banco de dados, protegidas por autenticação. Não existem em arquivos de código, configurações ou documentação.

2.2 Banco de Dados

- * **Acesso:** Protegido por autenticação (usuário + senha) e restrito por IP (whitelist) no Google Cloud SQL.
- * **Credenciais de acesso ao banco:** Não estão expostas publicamente. As variáveis de ambiente ficam configuradas apenas no servidor de produção (Render) e no ambiente local dos desenvolvedores.
- * **Dados dos clientes:** Armazenados em tabelas com acesso controlado pela aplicação, que exige login autenticado via Google OAuth para qualquer consulta.

2.3 Aplicação Web (Cortex)

- * **Autenticação:** Login via Google OAuth 2.0 - apenas emails autorizados (@turbopartners.com.br) têm acesso.
- * **Permissões:** Sistema de rotas permitidas por usuário - nem todos os colaboradores têm acesso à seção /acessos.
- * **Sessões:** Gerenciadas com tokens seguros, sem persistência em localStorage ou cookies acessíveis por JavaScript.

2.4 Infraestrutura

- * **Hospedagem:** Render (aplicação) + Google Cloud SQL (banco de dados).
- * **HTTPS:** Todo tráfego é criptografado via TLS/SSL.
- * **Variáveis de ambiente:** Configuradas diretamente no painel do Render, não versionadas no código.
- * **IP do banco de dados:** Restrito por firewall no GCP - aceita conexões apenas de IPs autorizados.

3. Conclusão

Com base na investigação realizada:

- * **1. As credenciais do cliente nunca estiveram expostas em código-fonte** - o repositório é privado e nenhuma credencial de cliente foi encontrada no histórico de commits.
- * **2. O acesso às credenciais requer autenticação em múltiplas camadas** - login Google OAuth na aplicação + permissão de rota + acesso ao banco protegido por senha e IP.
- * **3. Não há vetores de ataque identificados na infraestrutura da Turbo** que permitiriam a um agente externo obter as credenciais do cliente Forcell.
- * **4. A causa mais provável do comprometimento** está fora do perímetro da Turbo - exemplos comuns incluem: phishing direto ao cliente, reutilização de senhas em outros serviços comprometidos, malware no dispositivo do cliente, ou engenharia social.

4. Medidas Preventivas Já Implementadas

Mesmo sem evidência de falha, reforçamos proativamente a segurança:

Medida	Status
Repositório configurado como privado	Implementado
Senha do banco de dados alterada	Implementado
Acesso ao banco restrito por IP (whitelist)	Implementado
Histórico do Git limpo de qualquer dado sensível interno	Implementado
Credenciais de clientes armazenadas apenas no banco	Confirmado
Autenticação OAuth com restrição de domínio	Ativo

Conclusão final: A infraestrutura da Turbo Partners não apresenta falhas de segurança que justifiquem o comprometimento das credenciais do cliente Forcell. Recomendamos que o cliente investigue possíveis vetores de ataque em seu próprio ambiente (phishing, senhas reutilizadas, dispositivos comprometidos).